Security Incident Management Standard

From the Office of the Chief Information Officer, State of Minnesota

Version: 1.8
Effective Date: 1/1/2016
Revised: 12/31/2024
Approved: John Israel, State Chief Information Security Officer **Date:** 3/20/2025

Standard Statement

Security incident management controls must be in place to ensure the effective response and handling of information security incidents that affect the confidentiality, integrity, or availability of data that is stored, processed, or transmitted by the State.

Employees must abide by the terms of this standard. Employees who violate this standard may be subject to discipline, up to and including discharge.

Table 1. Security Incident Management Controls

Control Number	Control Name	Control Detail	Applicable Data Protection Categorization
1	Security Incident Management Plan	A security incident management plan must be developed and maintained that defines: • Roles and responsibilities. • Communication and contact strategies. • Specific security incident management procedures that: ○ Follow the centrally managed taxonomy for defining, validating, and classifying security incidents. ○ Provide notification to appropriate business owners, regulatory and/or law enforcement agencies. ○ Identify, reference, or include security incident management procedures from regulatory or law enforcement agencies. ○ Address alerts from security monitoring systems, including but not limited to intrusion detection, intrusion prevention, firewalls, and file integrity monitoring systems. ○ Coordinate incident management activities with contingency planning activities and data backup processes. • Analysis of legal requirements for reporting compromises. • Coverage and responses of all critical system components. • Metrics for measuring the security incident management capability. The security incident management plan must be reviewed and approved by appropriate leadership.	Low Moderate High
2	Security Incident Management Plan Distribution	Distribute copies of the security incident management plan to authorized incident management personnel, legal counsel, and data practices official.	Low Moderate High

Control Number	Control Name	Control Detail	Applicable Data Protection Categorization
3	Security Incident Management Plan Review	Review and update the security incident management plan at least annually to address: • System/organizational changes. • Problems encountered during plan implementation, execution, or testing. Communicate security incident management plan changes to authorized security incident management personnel, legal counsel, and data practices official.	Low Moderate High
4	Security Incident Management Training	Personnel must be trained in security incident management consistent with their assigned roles and responsibilities: • Within 90 days of assuming a security incident management role or responsibility. • When required by system changes. • At least annually.	Low Moderate High
5	Security Incident Management Testing	Security incident management capabilities must be tested at least annually. The test must: • Include tabletop exercises using scenarios that include a breach of regulated data and should test the agency's incident response policies and procedures. • Include a subset of all employees and contractors with access to regulated data in tabletop exercises. • Coordinate with authorized security incident management personnel, agencies, and third parties. • Be coordinated with organizational elements responsible for related plans. • Document results and address identified gaps. Produce an after-action report to improve existing processes, procedures, and policies. A formal test does not need to be completed if the organization actively exercises its response capability using real incidents.	Low Moderate High

Control Number	Control Name	Control Detail	Applicable Data Protection Categorization
6	Incident Handling	An incident handling capability for security incidents must be implemented that: • Includes designated personnel to be available on a 24/7 basis to respond to alerts. • Includes preparation, detection and analysis, containment, eradication, and recovery. • Coordinates incident handling activities with contingency planning activities. • Addresses unauthorized access, alteration, destruction, and disclosure of information. • Employs automated mechanisms to support the incident handling process including the availability of incident response-related information and support. • Incorporates lessons learned from ongoing incident handling activities into security incident management procedures, training and testing/exercises and implements the resulting changes accordingly. • Documents relevant information related to a security incident. • Preserves evidence is through: ○ Technical means, including secured storage of evidence media and "write" protection of evidence media. ○ The use of sound forensics processes and utilities that support legal requirements. ○ Determining and following chain of custody for forensic evidence. • Identifies vulnerability exploited during a security incident • Ensures security safeguards to reduce risk and exploit exposure for the identified vulnerability are implemented.	Low Moderate High
7	Incident Monitoring	All information security incidents must be tracked and documented.	Low Moderate High

Control Number	Control Name	Control Detail	Applicable Data Protection Categorization
8	Incident Reporting	Suspected security incidents must be reported to authorized security incident management personnel upon discovery. Automated mechanisms must be in place to assist in the reporting of security incidents.	Low Moderate High
9	Security Incident Management Assistance	Designated central incident management personnel must be available to respond to alerts and offer assistance for the handling and reporting of security incidents.	Low Moderate High
10	Information Spillage Response	Information spillage must be addressed by: • Identifying the specific information involved in the improper or potentially improper information disclosure. • Alerting authorized incident response personnel of the information spill using a method of communication not associated with the spill. • Isolating the contaminated information system or system component. • Identifying other information systems or system components on which the information may have been subsequently improperly or potentially improperly shared with or disclosed to. • Removing and destroying the information from the contaminated information system, component, or individual not authorized to handle the information.	Moderate High

Reason for the Standard

The State must respond to security incidents to ensure proper handling and corrective action is taken, as well as inform impacted parties in a timely manner in compliance with federal, state, and other applicable regulations.

Roles & Responsibilities

- Employees, Vendors, and Contractors
    - Be aware of and follow relevant information security policies, standards, and procedures.
    - Ensure information security is incorporated into processes and procedures.

    - Ensure contract language with vendors and contractors includes required information security controls.
    - Consult with information security staff on the purchase and procurement of information technology systems or services.
    - Contact information security staff or email GRC@state.mn.us with questions about the information security policies, standards, or procedures.
- Supervisors and Managers
    - Ensure employees and contractors are proficient in the information security policies, standards, and procedures that are relevant to their role.
    - Hold employees accountable for following the information security policies, standards, and procedures.
- Information Technology Personnel
    - Apply appropriate controls to the design, operation and maintenance of systems, processes, and procedures in conformance with the information security policies, standards, and procedures.
- Information Security Personnel
    - Develop, maintain, and assess compliance with the information security policies, standards, and procedures.
    - Develop, maintain, and implement a comprehensive information security program.
    - Provide training on information security policies, standards, and procedures.
    - Assist agencies and personnel with understanding and implementing information security policies, standards, and procedures.
    - Notify appropriate personnel of applicable threats, vulnerabilities, and risks to State data or systems.
- Agency Data Practices Personnel
    - Assist agencies and personnel with questions on proper data use, collection, storage, destruction, and disclosure.

Applicability

This policy applies to all departments, agencies, offices, councils, boards, commissions, and other entities in the executive branch of Minnesota State Government.

Related Information

Security Monitoring and Response Policy

State Standards and Authoritative Source Cross Mapping

Glossary of Information Security Terms

History

Table 2. Version History

Version	Description	Date
1.0	Initial Release	7/8/2015
1.1	Added Compliance Enforcement Date	12/29/2015
1.2	Updated Compliance Enforcement Date and Template	12/20/2016
1.3	Updated Compliance Enforcement Date and Template	10/26/2017
1.4	Scheduled Document Refresh	3/10/2020
1.5	Scheduled Document Refresh	11/1/2021
1.6	Scheduled document refresh	10/1/2022
1.7	Updated version number and revision date	10/1/2023
1.8	Added enforcement language; updated version and revision date	12/2/2024

Contact

GRC@state.mn.us